Projet de sécurité applicative

EXAMGUARD

Plateforme sécurisée de distribution, de protection et de traçabilité des examens numériques

Stéganographie – Watermarking – Fingerprinting
Confidentialité, intégrité et traçabilité des sujets d'examen

Encadrant : Mohamed-Bécha Kaâniche

Membres de l'équipe : Laith GRITLI
Ahmed ABDELHEDI
Mohamed Yassine AMRI

Pile technique : PWA React, Jakarta EE 11, WildFly 42, Java 25, PostgreSQL 18

Version : 2.0

Date : 12 novembre 2026

Année universitaire 2026–2027

Table des matières

Historique du document **1**

1 Présentation générale **2**
1.1 Contexte . . . 2
1.2 Problématique . . . 2
1.3 Présentation de la solution . . . 2
1.4 Objectifs . . . 3

2 Parties prenantes et utilisateurs **4**
2.1 Acteurs . . . 4
2.2 Autres parties prenantes . . . 4

3 Périmètre fonctionnel **5**
3.1 Modules fonctionnels . . . 5
3.2 Formats et limites . . . 6
3.3 Fonctionnalités exclues du périmètre . . . 6

4 Scénario métier principal **7**
4.1 Distribution sécurisée d'un sujet . . . 7
4.2 Limites d'interprétation des résultats . . . 7

5 Architecture technique **9**
5.1 Technologies retenues . . . 9
5.2 Vue logique . . . 10
5.3 Principes d'architecture . . . 10

6 Sécurité **11**

7 Organisation et livrables **12**
7.1 Répartition des responsabilités . . . 12
7.2 Planification . . . 12
7.3 Livrables . . . 13
7.4 Structure du dépôt . . . 13

8 Décisions arrêtées et risques du projet **14**
8.1 Décisions arrêtées depuis la version 1.0 . . . 14
8.2 Risques du projet . . . 14
Conclusion . . . 15

Historique du document

Version	Date	Description	Statut
1.0	06/11/2026	Première rédaction du cahier des charges pour la phase initiale.	Remplacée
2.0	12/11/2026	Version collective du trinôme : périmètre métier précisé ; algorithmes et bases de données choisis ; approche SRE contextualisée ; OWASP Risk Rating ; contrôles de cohérence, preuves détachées et protocoles de validation intégrés.	Soumise à validation

1. Présentation générale

1.1 Contexte

Les établissements universitaires manipulent des sujets d'examen qui doivent rester confidentiels avant leur diffusion officielle.

Ces documents sont préparés par des enseignants, puis transmis aux responsables d'examen chargés de les reproduire et d'organiser l'épreuve.

La circulation de copies numériques crée plusieurs risques : accès par une personne non autorisée, transmission accidentelle, modification du contenu, duplication ou divulgation avant la date prévue.

Le contrôle d'accès protège la plateforme, mais il ne distingue pas les exemplaires téléchargés et n'aide pas à analyser une fuite après distribution : une fois le fichier sorti du système, plus rien ne le rattache à la personne qui l'a reçu.

ExamGuard répond à cette problématique en plaçant les techniques de dissimulation de l'information au cœur du métier : chaque exemplaire distribué est unique et porte, de façon imperceptible, de quoi retrouver sa distribution.

1.2 Problématique

Comment une université peut-elle distribuer des sujets d'examen numériques aux seules personnes autorisées et, si l'un d'eux est divulgué, retrouver la distribution dont il provient tout en limitant le risque de fausse attribution et sans déduire automatiquement la culpabilité d'une personne ?

1.3 Présentation de la solution

ExamGuard est une application web progressive permettant à un enseignant de déposer un sujet et de le distribuer à des responsables d'examen.

Le système produit pour chaque destinataire un exemplaire individualisé ; un auditeur peut soumettre un fichier divulgué et obtenir un rapport d'attribution gradué.

Chaque exemplaire porte trois marques indépendantes, qui répondent à trois questions différentes et ne cèdent pas aux mêmes attaques :

	Watermarking	**Fingerprinting**	**Stéganographie**
Question	De quel examen provient ce fichier ?	De quelle distribution provient cet exemplaire ?	Le manifeste de distribution est-il authentique et resté lisible ?
Technique	DWT de Haar, DCT 8×8, modulation QIM	Décalage inter-mots de $\pm 0{,}40$ pt	*LSB matching* à parcours pseudo-aléatoire
Support	Bandeau d'en-tête de chaque page	Texte du sujet	Sceau PNG en dernière page (preuve portant sur ses champs)
Charge	48 bits, identique pour tous les exemplaires	64 bits, propre à chaque exemplaire	Manifeste signé et chiffré, 173 octets
Propriété	Robustesse visée face aux transformations du banc expérimental	Résistance au réenregistrement à démontrer sur le corpus	Fragile : les altérations de la charge sont détectées, pas forcément celles du PDF entier

Ces techniques ne remplacent ni l'authentification, ni l'autorisation, ni le chiffrement : elles prennent le relais là où ces contrôles s'arrêtent, c'est-à-dire une fois le fichier téléchargé.

Leurs paramètres figurent au chapitre 5 du recueil des besoins et leurs algorithmes détaillés dans les annexes de sécurité.

1.4 Objectifs

Les objectifs du projet sont mesurables ; les seuils sont repris sous forme d'exigences dans le recueil des besoins.

1. Permettre à un enseignant de déposer un sujet PDF et de le distribuer à 1 à 50 responsables d'examen.
2. Ne délivrer un exemplaire qu'à son destinataire, pendant la fenêtre de distribution, 3 fois au plus.
3. Produire des exemplaires dont le texte, la pagination et la longueur des lignes sont identiques à ceux de l'original.
4. Identifier les copies binaires exactes par leur condensé SHA-256 et, pour les copies transformées, évaluer un taux de récupération cible de 95 % sur le corpus de validation défini, sans attribuer automatiquement la fuite à une personne.
5. Ne jamais désigner un destinataire lorsque les marques sont contradictoires ; viser zéro fausse attribution dans le corpus déclaré, sans prétendre garantir ce résultat contre tout adversaire.
6. Chiffrer tous les sujets et exemplaires au repos et en transit.
7. Conserver une piste d'audit chaînée, dont les altérations dans le modèle de menace défini sont détectables grâce à des ancres signées conservées hors de la base.

2. Parties prenantes et utilisateurs

2.1 Acteurs

Acteur	Responsabilités	Droits principaux
Enseignant	Créer une session d'examen, déposer le sujet, désigner les destinataires, valider la distribution.	Gérer ses propres sessions et sujets ; consulter leurs distributions.
Responsable d'examen	Recevoir l'exemplaire qui lui est destiné.	Télécharger son seul exemplaire, pendant la fenêtre de distribution.
Auditeur	Analyser un fichier divulgué ; consulter les traces.	Investigation et journal d'audit en lecture seule ; second facteur d'authentification obligatoire.
Administrateur	Gérer les comptes et les rôles ; suivre les alertes.	Administration des comptes ; aucun accès aux sujets ni à l'investigation ; second facteur obligatoire.

2.2 Autres parties prenantes

— **L'établissement** (direction des études) : commanditaire ; il supporte les conséquences d'une fuite et d'une attribution erronée.

— **L'encadrant** : fixe les contraintes de l'atelier et valide les exigences.

— **Les personnes dont les données sont traitées** : les utilisateurs, dont les exemplaires sont individualisés et les téléchargements tracés ; ils en sont informés.

3. Périmètre fonctionnel

3.1 Modules fonctionnels

Le périmètre est dimensionné pour un trinôme : les trois mécanismes de dissimulation sont tous réalisés, avec leur détecteur et leur évaluation, ce qui constitue l'essentiel de l'effort métier.

Les exigences fonctionnelles détaillées (F-01 à F-21) sont spécifiées dans le recueil des besoins.

Module	**Rôle dans la solution**
Comptes et rôles	Authentification par mot de passe (Argon2id) et second facteur TOTP pour les rôles sensibles ; quatre rôles ; comptes créés par l'administrateur.
Examens et sujets	Création d'une session avec sa fenêtre de distribution ; import du sujet PDF, contrôle du fichier, condensé SHA-256, chiffrement AES-256-GCM.
Watermarking	Insertion et détection aveugle d'un filigrane de 48 bits identifiant l'examen dans le bandeau d'en-tête (DWT–DCT–QIM).
Fingerprinting	Insertion et détection d'une empreinte de 64 bits propre à chaque exemplaire, codée par décalage inter-mots dans le texte du PDF.
Stéganographie	Dissimulation et extraction du manifeste de distribution, signé (Ed25519) puis chiffré, dans un sceau PNG par *LSB matching*.
Distribution	Génération d'un exemplaire par destinataire ; téléchargement contrôlé ; reçu signé ; révocation.
Investigation	Analyse d'un fichier suspect par quatre détecteurs (condensé, filigrane, empreinte, manifeste) et rapport gradué par niveau de confiance.
Audit et tableau de bord	Journal chaîné des opérations sensibles, alertes de sécurité, vues de synthèse par rôle.
Banc d'évaluation	Mesure automatisée de l'imperceptibilité et de la robustesse des trois marques (PSNR, SSIM, taux d'identification, fausses attributions).

3.2 Formats et limites

— Les sujets sont des fichiers PDF d'au plus 20 Mio et 50 pages, non chiffrés et sans contenu actif.

— Un sujet doit comporter au moins 192 positions porteuses réellement modifiables, calculées sur l'ensemble des pages ; à défaut, le système refuse la distribution. Un nombre de mots brut ne suffit pas.

— Les fichiers soumis à l'investigation sont des PDF, ou des images PNG ou JPEG d'au plus 10 Mio et 40 mégapixels.

— Une session compte de 1 à 50 destinataires.

— La génération d'un exemplaire prend au plus 10 secondes pour un sujet de 10 pages ; une investigation, au plus 30 secondes.

— Les exemplaires, les distributions et les reçus sont conservés 12 mois après l'épreuve, de même que le journal d'audit.

3.3 Fonctionnalités exclues du périmètre

— Organisation des examens en ligne et surveillance des étudiants.

— Gestion des notes, des absences ou des résultats académiques.

— Traitement de vidéos et de flux audio.

— Reconnaissance faciale ou biométrique.

— Application mobile native.

Trois points sont des objectifs étendus, entrepris seulement si toutes les exigences prioritaires sont validées :

la résistance de l'empreinte à l'impression suivie d'une numérisation, l'identification des auteurs d'une collusion par un code dédié, et le marquage des sujets pauvres en texte.

4. Scénario métier principal

4.1 Distribution sécurisée d'un sujet

1. Un enseignant s'authentifie et crée une session d'examen en fixant les dates d'ouverture et de clôture de la distribution.
2. Il importe le sujet PDF. Le système contrôle le fichier, calcule son condensé SHA-256, mesure sa capacité de marquage et le chiffre avant stockage.
3. L'enseignant désigne les responsables d'examen destinataires et valide la distribution.
4. Pour chaque destinataire, le système génère un exemplaire : filigrane d'examen dans le bandeau, empreinte de distribution dans l'espacement des mots, manifeste signé et chiffré dissimulé dans le sceau.

   Il vérifie que les trois marques sont relisibles, puis calcule et signe hors du PDF le SHA-256 de chaque exemplaire final.
5. À l'ouverture de la fenêtre, chaque responsable se connecte et télécharge son exemplaire ; un reçu signé est conservé.
6. Si un sujet est divulgué, un auditeur soumet le fichier à l'investigation.
7. Le système vérifie aussi le condensé et le reçu détaché de l'exemplaire exact, confronte les marques et produit un rapport gradué ; il s'abstient lorsqu'une conclusion ne peut pas être corroborée.

Portée des preuves. Un manifeste Ed25519 extrait d'un sceau authentifie seulement les champs signés (et la liaison déclarée à l'original).

Il ne prouve *pas* à lui seul que les octets du PDF final n'ont pas été modifiés.

Le condensé de l'exemplaire final est donc conservé dans un *enregistrement détaché signé* (hors PDF, afin d'éviter l'auto-référence circulaire).

L'attribution d'une distribution est une propriété technique d'un exemplaire, jamais une détermination de l'auteur humain de la fuite.

4.2 Limites d'interprétation des résultats

Une marque rattache un fichier à une distribution, non à une personne : l'exemplaire a pu être dérobé à son destinataire.

Le rapport d'investigation est un indice technique.

Il s'abstient de désigner une distribution lorsque les marques sont invalides ou se contredisent, et porte une mention explicite sur sa portée (exigence ES-DIS-09 du recueil des besoins).

Les risques non couverts, dont la photographie d'écran et la ressaisie du texte, sont déclarés au chapitre 11 du recueil.

5. Architecture technique

5.1 Technologies retenues

Les choix ci-dessous constituent la **baseline de conception proposée par le trinôme** ; ils ne sont pas des garanties expérimentalement démontrées.

Leur justification détaillée figure dans le recueil des besoins (décisions DT-01 à DT-15).

Domaine	**Choix**
Client	PWA React (SPA) ; *service worker* limité aux ressources statiques.
Middleware	Jakarta EE 11 sur WildFly 42 et Java 25 : Jakarta REST 4.0, CDI 4.1, Security 4.0, Persistence 3.2, Validation 3.1.
Base de données	PostgreSQL 18, sur un hôte distinct ; rôles à privilèges réduits.
Stockage des fichiers	Système de fichiers privé hors racine web ; chaque fichier chiffré par AES-256-GCM avec sa propre clé.
Mots de passe	Argon2id (RFC 9106) : 64 Mio, 3 itérations, 4 voies ; Bouncy Castle.
Cryptographie	AES-256-GCM, HKDF-SHA-256, Ed25519, SHA-256, par l'API JCA de Java 25.
Clés	*Credential store* Elytron de WildFly ; aucune clé dans le dépôt.
Transport	TLS 1.3 uniquement, côté client comme vers la base.
Traitement des PDF	Apache PDFBox 3.0.x.
Watermarking	DWT de Haar, DCT 8×8, modulation d'index de quantification.
Fingerprinting	Décalage inter-mots sur PDF textuel admissible, codage continu entre pages et détection informée ; résistance à la collusion non garantie.
Stéganographie	*LSB matching*, parcours piloté par ChaCha20.
Journal d'audit	Table en ajout seul, chaînée par SHA-256, ancre quotidienne signée.

5.2 Vue logique

Architecture logique d'ExamGuard

Le diagramme de déploiement figure au chapitre 7 du recueil des besoins ; les flux de données et leurs frontières de confiance, dans les annexes de sécurité.

5.3 Principes d'architecture

— Le serveur est l'autorité pour l'identité, les droits et l'état des distributions ; le client ne détient aucun secret et aucune donnée confidentielle n'y est mise en cache.

— L'accès est refusé par défaut ; chaque requête est contrôlée par rôle et par objet.

— Les fichiers persistants restent chiffrés ; les traitements PDF sont isolés avec un espace temporaire maîtrisé et purgé.

Aucun document n'est servi depuis une racine web publique.

— La sécurité des marques repose sur le secret des clés, non sur celui des algorithmes, qui sont publiés dans le dépôt.

— Chaque composant s'exécute avec les privilèges minimaux, y compris les rôles de PostgreSQL ; les points d'entrée sont contrôlés par rôle *et* par objet.

6. Sécurité

Les aspects de sécurité suivent l'agenda du cours et relèvent d'une démarche d'ingénierie des exigences de sécurité (*Security Requirements Engineering*), décrite dans le recueil des besoins (`docs/recueil_des_besoins.pdf`) et ses annexes (`docs/annexes_securite.pdf`).

Ils ne sont pas répétés ici afin d'éviter toute incohérence entre les deux documents.

En résumé :

— **Approche** : cas d'abus puis cas d'utilisation de sécurité, complétés par des récits d'abus et de sécurité suivis dans le dépôt ; ce choix est justifié par comparaison avec SQUARE et OCTAVE.

— **Analyse** : 12 cas d'abus (effacement des marques, collusion, accusation erronée, stéganalyse), 18 menaces STRIDE évaluées selon OWASP Risk Rating (vraisemblance, impact technique et impact métier), et arbres d'attaque.

— **Spécification** : 57 exigences de sécurité réparties en 13 familles, chacune munie d'un mécanisme, d'un seuil chiffré, d'un test, d'une priorité et d'une itération.

— **Validation** : critères de vérification pour chaque exigence, 12 tests d'abus, essais adversariaux et banc de marquage ; les résultats restent à produire, les seuils sont des cibles de conception.

7. Organisation et livrables

7.1 Répartition des responsabilités

Chaque membre est responsable d'un lot comprenant un mécanisme de dissimulation et une partie de la plateforme.

Toute contribution touchant la sécurité est relue par un autre membre.

Lot	**Contenu**	**Responsable**
A – Marquage du texte	*Fingerprinting* par décalage inter-mots et son détecteur ; chaîne PDF (import, contrôle, génération des exemplaires).	Laith GRITLI
B – Marquage d'image et cryptographie	*Watermarking* DWT–DCT–QIM, stéganographie et leurs détecteurs ; chiffrement au repos, clés, signatures.	Ahmed ABDELHEDI
C – Plateforme et contrôle d'accès	Authentification, sessions, autorisation, journal d'audit et alertes ; PWA React ; déploiement.	Mohamed Yassine AMRI
Commun	Investigation et rapport (intégration des détecteurs), banc d'évaluation, tests d'abus, documentation, revues croisées.	Trinôme

7.2 Planification

Les itérations suivent les chapitres du cours ; le détail des exigences par itération figure au chapitre 10 du recueil des besoins.

It.	**Chapitre du cours**	**Résultat attendu**
1	3 – Confidentialité, intégrité, disponibilité	Import d'un sujet, chiffrement, génération d'exemplaires portant les trois marques.
2	4 – Authentification, autorisation, informations privées	Comptes, rôles, distribution et téléchargement contrôlés ; PWA.
3	5 – Journalisation et gestion des erreurs	Journal chaîné, alertes, investigation et rapport gradué.
4	6 – Tests de sécurité	Banc d'évaluation, tests d'abus, analyse dynamique, tests de charge.
5	7 – Déploiement et maintenance	Déploiement durci, sauvegarde et restauration, rotation des clés.

7.3 Livrables

— Dépôt GitHub contenant le code source et l'historique de progression.

— Cahier des charges, recueil des besoins et annexes de sécurité au format PDF sous `docs/`, avec leurs sources.

— Documentation de l'architecture, du modèle de données et de l'API (contrat OpenAPI).

— Rapports de test par itération : tests d'exigences, tests d'abus, mesures du banc d'évaluation, analyse dynamique.

— Guide d'installation, de configuration et de démonstration.

7.4 Structure du dépôt

```
ExamGuard/
|-- docs/
|   |-- cahier_des_charges.pdf
|   |-- recueil_des_besoins.pdf
|   |-- annexes_securite.pdf
|   |-- src/              sources LaTeX des documents
|   |-- rapports/         rapports de test par iteration
|-- frontend/             PWA React
|-- backend/              application Jakarta EE
|-- tests/
|   |-- marking-bench/    banc d'evaluation du marquage
|   |-- abuse/            tests d'abus de bout en bout
|-- deploy/               configuration WildFly et PostgreSQL
|-- .github/workflows/    integration continue
|-- README.md
```

8. Décisions arrêtées et risques du projet

8.1 Décisions arrêtées depuis la version 1.0

Point ouvert en v1.0	**Décision**
Base de données et persistance	PostgreSQL 18, accès par Jakarta Persistence 3.2.
Algorithme de *watermarking*	DWT de Haar, DCT 8×8, modulation QIM, dans le bandeau d'en-tête ; évalué face à la compression JPEG, au redimensionnement, au bruit et à la conversion de format.
Méthode de *fingerprinting*	Décalage inter-mots de $\pm 0{,}40$ pt dans le texte du PDF ; mot de code de 64 bits répété au moins 3 fois.
Place de la stéganographie	Sceau PNG inséré en dernière page de chaque exemplaire ; il transporte le manifeste de distribution signé puis chiffré.
Limites de taille, quotas, conservation	20 Mio et 50 pages par sujet ; 50 destinataires ; 3 téléchargements ; conservation de 12 mois.

8.2 Risques du projet

Risque	**Parade**
La manipulation fine de la position des mots avec PDFBox s'avère plus complexe que prévu.	Prototype dès la première semaine de l'itération 1, sur des PDF à texte simple ; le périmètre se limite aux paragraphes de texte courant.
Un seuil de robustesse n'est pas atteint lors des mesures.	Les paramètres (Δ, pas de quantification, nombre de répétitions) sont configurables ; tout écart est traité par le processus de gestion des exigences, avec l'accord de l'encadrant.
Une bibliothèque se révèle incompatible avec WildFly 42 ou Java 25.	Vérification de compatibilité à l'itération 1 ; les primitives cryptographiques sont celles du JDK, hors Argon2id.

La charge de travail dépasse la capacité du trinôme.	Les exigences sont priorisées (P1 à P3) ; les objectifs étendus sont hors engagement.

Conclusion

ExamGuard est un travail collectif du trinôme, conçu pour l'atelier de sécurité applicative.

Les décisions de conception, les exigences et les critères de validation sont soumis à la revue de l'équipe et de l'encadrant.

La stéganographie, le *watermarking* et le *fingerprinting* ont chacun un rôle distinct et nécessaire : identifier l'examen, identifier la distribution, et authentifier les champs du manifeste de l'exemplaire.

Le périmètre est dimensionné pour un trinôme, les choix techniques sont arrêtés et les objectifs sont chiffrés.

Ce cahier des charges est complété par le recueil des besoins, qui spécifie les exigences fonctionnelles et de sécurité et les moyens de les vérifier.

Les deux documents évolueront avec l'agenda du cours, selon le processus de gestion des exigences décrit dans le recueil.